1 多智能体自动化渗透测试

1.1 几种主流的协同组织模式：

（1）中心化编排：一个总控智能体负责全局规划、任务分派和优先级调度，下面挂若干专业智能体（侦察、利用、验证、记忆等）。总控不直接碰工具，专业智能体只在自己领域内执行。

（2）半去中心化/战略—战术分层：上层保留战略规划，下层赋予战术执行一定的自主权，避免所有细碎决策都挤回中心节点造成瓶颈。

（3）按渗透阶段/任务域分解：不设一个强总控，把渗透测试流程本身切成若干领域边界清晰的模块，每个模块由专门的智能体或子系统负责，模块之间通过结构化状态或共享工作区衔接。

（4）黑板架构（Blackboard）：所有智能体不直接互相“喊话”，而是读写一块共享工作区（黑板）。黑板上记录已知事实（Fact）、待验证意图（Intent）、线索提示（Hint），各个专业智能体按自己的职责读取和写入，总控或调度器根据黑板状态决定下一步。

1.2 优缺点

（1）中心化编排（Orchestrator + 专业 Agent）：

优点：任务分派有明确的优先级依据，不是“谁先谁后靠猜”。 有量化证据表明中心化编排能同时提升完成率和降低幻觉。安全控制可以集中在编排层统一实施。

缺点：中心节点本身容易成为性能和适应性的瓶颈。调度策略的设计质量直接决定系统上限。单点故障和单点攻击面。

（2）半去中心化/战略—战术分层

优点：它直接针对中心化编排的两个具体病症：指导低效和命令不精确。 在保持战略连贯性的同时获得战术自主，避免了“一管就死、一放就乱”的两个极端。实证上相对单智能体基线有更好的完成效果和稳定性。

缺点：战略层与战术层之间的“接口”本身就是新的设计负担。角色拆分本身会带来协调成本。战略层规划错误仍会向下传导。

（3）按渗透阶段/任务域分解

优点：结构化状态管理直接补偿“记不住、接不上”问题。阶段/任务域分解在子任务完成率上有可量化的提升。每个模块只面对自己领域的最小工具集和知识域，减少工具选择噪声。

缺点：接口和状态传递是核心难点，上游的微小错误会被下游放大。固定的阶段划分可能跟不上非线性的真实渗透路径。模块越多，协调和评估的复杂度越高。

（4）黑板架构（Blackboard）

优点：可解释性是结构性的，不是事后补的。新增能力不必改写编排器，可扩展性更强。并发和“涌现式”攻击链是可能的。

缺点：黑板本身的设计成为新的核心复杂点。“不预设角色”在带来灵活性的同时，也提高了调试和保证一致性的难度。污染传播是黑板架构的固有风险。调度机制仍然存在。

2 如何实现资产和服务的自动发现（数据来源）

网络域：有哪些网络设备、如何连接、流量关系 Netflow/IPFIX/sFlow

LLDP/CDP 邻居发现、SNMP查询

物理域：机房里"多少什么多什么"及其位置、设备信息、异常、未登记设备

U位传感器 RFID 机器视觉巡查+U位异常分类 tag

硬件健康域：部件的健康状态、BMC事件日志、硬盘渐进性退化趋势。

带外BMC轮询 SMART与趋势分析

应用服务域：运行中的进程、监听端口、应用类型、服务间上下游与依赖

进程/端口级发现 无侵入socket映射+分布式调用链追踪

虚拟化域：物理宿主机、虚拟机/容器、集群、宿主机到VM的关系、数据存储

↘通过虚拟化平台的原生API或Agentless头读发现

存储域：存储阵列、存储池、LUN、文件系统、FC端口、NFS/SMB服务、主机到存储的挂载/映射

↘存储管理API/SNMP，按厂商和设备代际选择路径。

安全域：资产漏洞暴露面、配置基线合规状态、安全弱点（弱口令、未授权访问、etc）

漏洞扫描 配置基线核查、CMDB/ITSM联动做资产闭环。

云与混合资源域：云服务器、负载均衡、数据库、存储、VPC网络、Serverless资源归属关系。

↘订阅API和配置/事件服务

动力环境域：机房温湿度、漏水、烟感、空气质量、精密空调状态、门禁等。

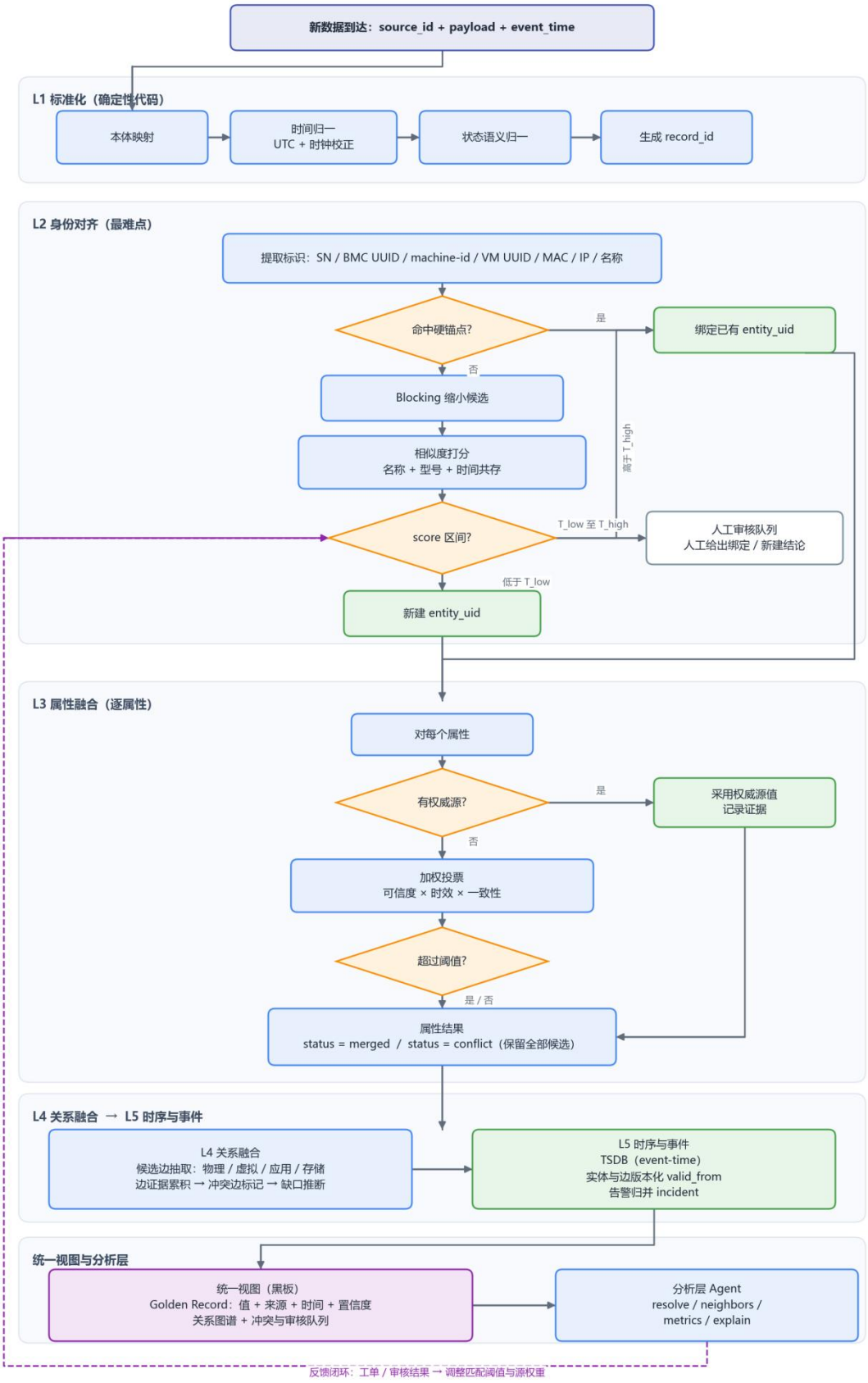
传感器、协议转换网关+平台汇聚

电力与能耗域：PDU/UPS状态、机柜级/设备级功耗、电流电压、列头柜电力参数。

智能PDU、UPS 列头柜电表。

3 数据融合问题

3.1 事实融合



（1）标准化

标准化阶段解决"同一事物、不同表达"的问题。

具体包括：本体映射，将源系统字段对应到模型属性；时间归一，将所有时间戳统一为 UTC 并校正时钟偏差，同时保留事件发生时间而非入库时间；状态语义归一，将 Up/在线/1/正常等不同表述映射为统一枚举；生成记录标识 record_id，作为该条数据的稳定引用。

（2）身份对齐

判定一条新记录属于已有实体还是代表一个新实体。首先从记录中提取标识集合，并按可靠性排序（例如：硬件序列号、BMC/Redfish UUID、主机 machine-id、虚拟机 UUID、MAC 地址、IP 地址与名称）。随后按以下三种情况处理。

命中硬锚点。当记录中的序列号或 UUID 与已有实体匹配时，直接将记录归并到该实体，并把本次出现的 IP、主机名、CMDB 编号等登记为带有效期的别名，而非覆盖原有字段。

未命中硬锚点。此时通过分桶（按网段、名称前缀、MAC 厂商、时间窗）缩小候选集，再综合名称相似度、型号与厂商一致性、标识时间共存性进行打分。

按分数区间决策。分数高于高阈值时自动归并；落入高低阈值之间时进入人工审核队列，由人工给出绑定或新建结论；低于低阈值时新建实体。该策略遵循"宁可不合并，不可错合并"的原则，并保留合并历史以支持拆分与回滚。

（3）属性融合

对记录中的每个属性，先查询属性—权威源矩阵：若当前数据源是该属性的权威源，则直接采用该值并记录证据；否则依据源可信度、时间新鲜度与多源一致性进行加权投票。融合结果显式标注状态：取值一致且可信为 merged，无法达成一致为 conflict 并保留全部候选值，由规则推导得到为 inferred。系统不以静默覆盖的方式消除冲突，以保证后续分析可解释。

此外，流程将"应有而无"作为一种证据：依据拓扑与采集能力推导某设备本应上报的数据，若实际缺失，则判定为故障信号而非未知状态。

（4）关系融合

关系融合从记录中抽取实体之间的候选关系，按物理、虚拟、应用、存储四类分别处理：物理关系包括设备—机柜—U 位—PDU 与 LLDP 邻居；虚拟化关系包

括虚拟机—宿主机—集群—存储；应用关系包括进程、端口与服务调用链；存储关系包括主机—LUN—阵列。关系边采用多源证据累积，被越多来源观测到可信度越高；来源之间矛盾的关系边被显式标记；拓扑缺口依据标签、配置与规则推断补全。关系图里的每一条线，都要说清楚它有多可信、有没有争议、是不是猜出来的。

（5）时序与事件

时序与事件阶段负责将融合结果落入可持续查询的形态。指标按事件时间写入时序库。实体与关系采用版本化存储，记录生效与失效时间，支持按任意历史时刻查询。状态变化与告警按照拓扑关联和时间窗口归并为 incident。变更、发布与工单作为离散事件写入时间轴，供根因分析与影响分析使用。

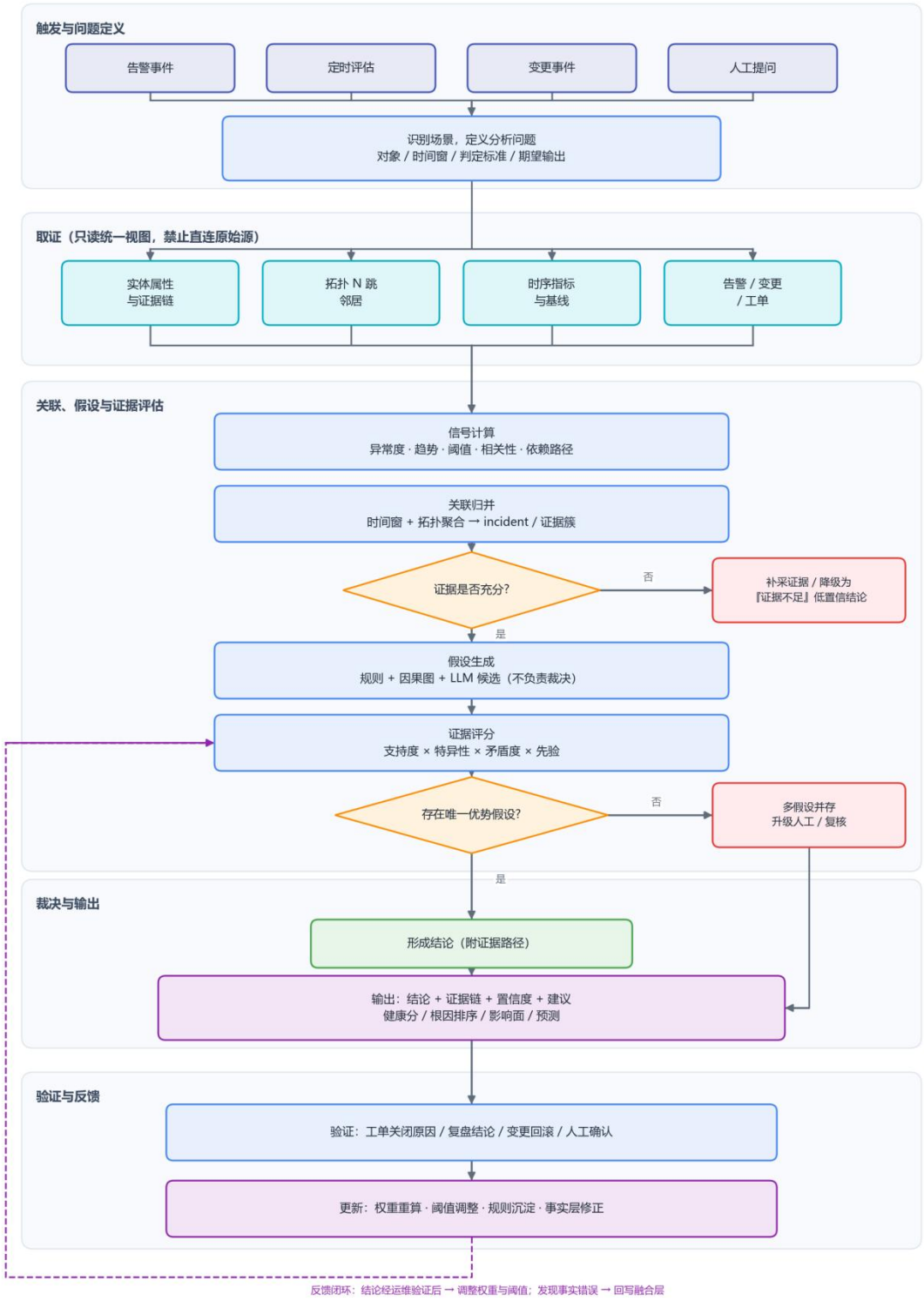
（6）统一视图与分析

上述各阶段的产出统一写入黑板，包括带来源、时间与置信度的 Golden Record，实体关系图谱，以及冲突与审核队列。黑板是各阶段之间唯一的数据介质，避免同一数据存在多条通路而导致视图不一致。分析层智能体通过 resolve、neighbors、metrics、explain 四类接口读取融合结果，不直接访问原始数据源。

（7）反馈闭环

工单关闭原因、变更确认结果与人工审核结论会回写到融合内，用于更新数据源权重与身份匹配阈值。

3.2 综合分析/判断融合



（1）触发与问题定义

综合分析由告警事件、定时评估、变更事件或人工提问触发。触发后首先识别分析场景，并明确三项前提：分析对象、时间窗与判定标准。分析对象决定取证范围，时间窗决定证据的时效边界，判定标准决定结论的形式与阈值。

（2）取证

在既定范围内抽取四类证据：实体属性及其证据链、拓扑上 N 跳范围内的邻居、时间窗内的指标序列与历史基线，以及告警、变更与工单等事件。该阶段只读取融合后的事实，不回溯原始数据。

（3）信号计算

将事实转化为可以相互比较的信号，包括异常度、变化趋势、阈值越界、相关性以及依赖路径。信号是不同来源证据的共同语言，使来自硬件、网络、动环与业务系统的证据能够在同一尺度上比较。

（4）关联归并

按时间窗与拓扑邻接关系对信号进行聚合，将同一根因引发的多条告警被归并为一个事件，避免逐条分析造成重复判断与结论冲突。

（5）假设生成

针对聚合后的证据簇生成候选解释或候选根因。候选来源包括基于拓扑与变更的规则、因果图推理，以及大语言模型提出的假设。

（6）证据评分

对每个候设计算综合得分，评分维度包括支持度（对假设的支撑程度）、特异性（假设能解释多少细节）、矛盾度（与已确认事实的冲突程度）与先验概率（该类故障在历史数据中的发生频率）。

（7）判断与裁决

第一，证据是否充分：若证据不足以支撑，则补采证据；补采后仍不充分，则降级输出低置信结论并显式标注"证据不足"，不以推测代替结论。

第二，是否存在唯一优势假设：若某假设显著优于其他假设，则形成结论；若多个假设得分接近，则保留多假设并存，升级人工复核。

（8）输出

分析结果统一表达为结论、证据链、置信度与处置建议四部分。

（9）验证与反馈

结论通过工单关闭原因、故障复盘结论、变更回滚情况与人工确认进行验证。结果用于：重新计算数据源与证据权重、调整判定阈值、沉淀为可复用规则。